AI for Good Sandbox Hackathon - “Team Djotta”
SarkiAI Policy Sandbox: health-data incident response under national law

Team leader: Muller Roufaou
Team members: HABIBA Issa Muller, BALOG Thèrese Christine
Contact details: muller.roufaou@djotta.com, +237 696 171 176
Github link: https://github.com/rouftom/sarkiai-policy-sandbox
Country: Cameroon

1. Introduction

   - in public health, telecoms and other public services, incidents on digital platforms (a breach of patient records, a wave of SIM-swap fraud) are reported by hospitals, operators, media and citizens.

   - several institutions must respond, each under its own law: the Ministry of Public Health, the personal data protection authority, the national cyber agency (ANTIC), the telecom regulator (ART).

   - facts reach each institution at different times; the texts are scattered across laws, decrees and CEMAC directives, partly scanned, in French and English.

   - routing each fact to the competent institution, with its background context (which platform, which data, which users, since when), within its mandate and deadline, is critical.

   - recommendations must be explained afterwards and approved by a named official.

   What is the role played by AI?

   - local language models (qwen3.5:9b, bge-m3) running on national infrastructure, in French and English.

   - context provided by the KB: the national legal corpus, quoted article by article.

   - policy guidelines applied: legal mandates, citation check, human approval, audit log.

   Requirements

   - it is critical that every recommendation rests on a provision present in the national corpus, and that the system says so when the corpus is silent.

   - it is critical that no incident data leaves national infrastructure and that the operations of the hospital are not impacted: the system advises, officials decide.

   - it is expected that each institution only receives the facts within its mandate, and that a joint report is produced in a minimal number of steps.

   - it is of added value that another institution reuses the same framework by swapping its context KB, without new code.

Demo scenarios:

- scenario-1: step-1: the solution is online. The crisis cell of the Ministry of Public Health, the data protection authority and ANTIC handles an anomalous access to the national e-health platform.

- step-2: after a while, the hospital asks why the agents recommended suspending remote access to the platform, when it was working normally for its staff.

- traceability and explainability.

- step-3: the recommendations conflict. The cyber agent asks to isolate the platform, the health agent requires continuity of care, and the data protection agent asks to keep the access logs, which contain the IP addresses and locations of users.

- user privacy guidelines.

- step-4: the same solution is adopted in the telecom sector by the regulator (ART) for a wave of SIM-swap fraud complaints. The KB context is different, but the same interface and P rules apply. Swapping the context KB, reuse and cost reduction are achieved with the framework.

- strategy to reduce the overall cost.

Demo:

1) Highlight the scenarios (Section 5).
2) Standards, policies, gaps (Sections 4 and 6).

2. Description of the use case

The problem. When patient records leak from a public hospital connected to the national e-health platform, the Ministry of Public Health answers for continuity of care, the data protection authority for the law of 23 December 2024, ANTIC for the cybersecurity law 2010/012, and the telecom regulator when networks are involved. No actor holds the full picture, and the outcome depends on who read which text first.

The solution. SarkiAI Policy Sandbox gives each institution an AI agent bound to its legal mandate, releases the facts progressively and produces a joint report in which every claim quotes its article; a coordinator brings conflicts between mandates to light and a named official approves any action. The engine also scores the 13 ITU readiness dimensions.

Gaps in existing solutions, and how the solution closes them. Coordination by meetings and letters is slow and leaves no shared record: the sandbox runs one scenario for all institutions and merges their assessments into a single joint report. Generic AI assistants answer without a verifiable legal basis and cannot say that the law is silent: here, each quote is matched against the retrieved corpus, an invented quote is rejected and the answer regenerated, and a gap is declared when no provision applies. Cloud AI would send incident data abroad: here, inference is local by construction. Nobody can reconstruct who

decided what, on which basis: here, the audit log is re-verifiable, the run is exported as a dossier, and each approval is a signed, single-use link.

3. Use case requirement

   Each node of the ML pipeline (ITU-T Y.3172) is associated with requirements:

   - **SRC:** only official texts and openly licensed public documents enter the published KB, each with its issuer and provenance; incident data are fictional in the sandbox, and in deployment only the facts needed for the response are shared, never patient records.
   - **C:** scanned gazettes go through local OCR (Tesseract), with the page zone kept as provenance, so that no text enters the KB from a bad scan unnoticed.
   - **PP:** legal texts are split by structure (title, chapter, article) and tagged with country, jurisdiction, document type and readiness dimension; incident facts are released in blocks, and each agent only receives the blocks within its mandate.
   - **M:** generation and embeddings run locally in Ollama, with hybrid retrieval (dense and BM25, RRF fusion). The reference sandbox needs 8 to 16 vCPU, 32 GB RAM and 40 GB of disk, with no GPU; no request leaves the host.
   - **P:** every claim cites a provision present in the retrieved corpus; agents act within their mandate (what they can and must not do); any notification or public statement requires a human approval.
   - **D:** the coordinator merges the assessments into a joint report listing agreements, conflicts and open questions; every step is written to the audit log and can be re-verified end to end.
   - **SINK:** officials read the joint report, the citations and the audit trail in a bilingual console (French and English) and export the run dossier.

4. Mapping with ITU-T Y.3172 Readiness 2.0 Report, and domain-specific policies

	Use case (incident response, public health domain)	**Readiness 2.0 Report**	**Documents (policies, strategies, regulations)**
SRC	National legal corpus; incident facts from the hospital and the e-health platform	D1 Data/Model Marketplace; D13 Digital Infrastructure	PSNSN 2026-2030 (digital health plan); health compact (CSU) 2023; SND30; Plan stratégique Cameroun Numérique 2020
C	Ingestion service, local OCR of scanned gazettes, upload from the console	D5 Integration of AI in Workflows; D13 Digital Infrastructure	Decree on electronic certification; Law 2010/012 on cybersecurity and cybercrime
PP	Article-level chunking, jurisdiction tagging, release of facts by block and by mandate	D1 Data/Model Marketplace; D3 Cross-Domain Correlation; D6 Human Interface	Law of 23 Dec. 2024 on personal data protection; CEMAC directive on users' rights
M	Local models (qwen3.5:9b, bge-m3), hybrid retrieval	D4 Contextualization and Regional Impact; D13 Digital Infrastructure	AU Continental AI Strategy 2024; Smart Africa AI Blueprint; Malabo Convention*

	Use case (incident response, public health domain)	Readiness 2.0 Report	Documents (policies, strategies, regulations)
P	Citation check, mandates, signed human approvals	D10 AI & Policies; D9 Impacts of Humans; D7 Strategy Alignment	Law of 23 Dec. 2024; Law 2010/012; Penal Code 2016; WHO guidance on AI for health*
D	Coordinator, joint report, hash-chained audit log	D8 Collaboration with AI; D5 Integration of AI in Workflows	Law 2010/012 (security audits); ITU-T Y.3172*
SINK	Officials of the ministry, the authority and ANTIC; bilingual console; dossier export	D6 Human Interface; D11 AI for Inclusion; D12 Granular Priorities	Law of 23 Dec. 2024; CEMAC directive on users' rights; UNESCO Recommendation on the Ethics of AI*

* Framing references, cited by their official link: the agents do not quote them.

Knowledge base. 21 Cameroonian documents collected; 18 published with the repository (17 official texts and a World Bank ID4D diagnostic under CC BY 3.0 IGO), 3 kept local for rights reasons (a press page, a research paper, an authored article). Five instruments are still to source: the constitution, the health framework law 96/03, the data protection authority text, the ANTIC mandate and the cyber strategy. Ten African strategies come from the ITU reference repository; the ITU taxonomy (6 factors, 13 dimensions, 111 metrics) drives the readiness scoring.

5. Error scenarios

Step 1: the solution works. Facts are released in three blocks: an anomalous access, a possible exfiltration of patient records, then media pressure and a notification deadline. Each agent assesses only the blocks within its mandate, citing its articles; the coordinator merges the assessments into one joint report.

Step 2: traceability and explainability. The answer to the hospital is read from the record, not regenerated. The run dossier shows the facts the cyber agent held at that block, the passages retrieved, the article quoted, the model used and the hash of each step: the recommendation rests on a possible exfiltration, not on the availability of the service. **Controversy:** if the quoted passage does not support the recommendation, the dossier makes it visible, and the error is recorded instead of defended.

Step 3: user privacy guidelines. The coordinator lists the conflict between isolation, continuity of care and evidence preservation, with each position, the provisions in tension and a severity; it does not decide. The data protection agent applies the law of 2024: the logs are personal data, so only what the investigation needs is kept, for a stated purpose. Agents cannot notify or publish: a named official decides through a signed, single-use approval, and the choice is logged. **Controversy:** when the corpus does not say which duty prevails, or how long such evidence may be kept, the joint report states it as an open question and the gap is recorded (gaps 2 and 4).

Step 4: strategy to reduce the overall cost. The telecom regulator runs the SIM-swap fraud scenario on the same engine, console and P rules. The domain selects the institutions and their mandates, and the context comes from the telecom texts of the KB (ART compilation 2018, MINPOSTEL compendium 2023, electronic communications law, CEMAC directive). A new ministry or country only adds its corpus through a manifest and one ingestion run: no code change, no new model, the same CPU-only hardware. **Controversy:** reuse does not mean trusting another institution's answers: agents only quote what the active corpus contains, and the citation check rejects any quote absent from it.

Where the solution can fail. If the model invents a passage, the check rejects it and forces a new attempt; if attempts run out, the answer is shown as unverified, with a lower confidence and a gap in the audit log. Until the five missing instruments are sourced, and the ART compilation 2018 is OCR'd (its text layer is poor), the gaps below are provisional. The solution supports officials; it is neither legal advice nor an automatic decision.

6. Policy gaps and standards gaps derived from the mapping exercise

Each gap is a provision we looked for in the collected corpus and did not find.

#	Type	Gap	Dim.	Recommendation
1	Law	Notification duties not allocated across sectors: each authority waits for another	D10, D7	Designate a lead authority and an escalation path
2	Law	No rule on which duty prevails between containment and continuity of care	D10, D9	Define a precedence rule or an arbitration body
3	Standard	No machine-readable traceability of AI recommendations used by public bodies	D5, D6	Require an audit artefact per decision: citations, model, hash chain
4	Policy	Retention and minimisation of incident evidence (logs with locations) not specified	D1, D10	Set retention limits and access rules for incident evidence
5	Standard	Interoperability formats and metadata for health data are not binding	D1, D3	Make standard formats and metadata mandatory
6	Infrastructure	No availability or redundancy requirement for critical e-health services	D13	Set availability requirements for AI-assisted public services
7	Policy	No rule on liability when an official follows an AI recommendation	D10, D9	Allocate liability; require a named approver, logged (already enforced in the sandbox)
8	Standard	ITU-T Y.3172 has no explicit control for the legal grounding of generated outputs	D10, D5	Add a citation check function at node P in sandbox profiles